

Protocolo de Ciberseguridad para PYMES: Guía de Implementación Práctica

Autor: Agencia de Ciberseguridad de la Comunidad Valenciana

Diagnóstico y Evaluación de Riesgos

La ciberseguridad no es un problema exclusivo de las grandes corporaciones. El 43% de los ciberataques a nivel global tiene como objetivo a pequeñas y medianas empresas, que a menudo presentan superficies de ataque más amplias y menos protegidas que las organizaciones de mayor tamaño. En España, el INCIBE registró más de 83.000 incidentes de ciberseguridad en 2023, de los cuales el 65% afectó a entidades con menos de 50 empleados.

La primera acción para cualquier PYME debe ser la realización de un inventario completo de activos digitales (hardware, software, datos, servicios cloud) y la identificación de los riesgos asociados a cada uno de ellos mediante una metodología estructurada como MAGERIT o la adaptación simplificada propuesta por el Esquema Nacional de Seguridad para entidades de perfil bajo.

Medidas Técnicas Prioritarias

Con independencia del sector y del tamaño de la organización, existe un conjunto de controles técnicos básicos cuya implementación reduce de forma drástica la probabilidad de sufrir un incidente grave: autenticación multifactor (MFA) en todos los servicios críticos, gestión centralizada de parches y actualizaciones de seguridad, segmentación de la red corporativa con VLAN separada para dispositivos IoT y visitantes, solución de backup 3-2-1 con copias verificadas regularmente y una copia offline, y solución EDR (Endpoint Detection and Response) en todos los equipos de trabajo.

La concienciación y formación continua del personal constituye, estadísticamente, la medida con mayor retorno sobre la inversión en ciberseguridad, dado que el factor humano está implicado en el 74% de las brechas de seguridad documentadas.

Plan de Respuesta a Incidentes

Toda organización, independientemente de su tamaño, debe contar con un Plan de Respuesta a Incidentes (PRI) documentado, conocido y practicado. Este plan debe definir los roles y responsabilidades del equipo de respuesta, los criterios de clasificación y escalado de incidentes, los procedimientos de contención, erradicación y recuperación, y los requisitos de notificación a autoridades competentes (AEPD, INCIBE-CERT) en los plazos legalmente establecidos por el RGPD y la Directiva NIS2.

